Semana 04 — Medir lo expuesto y comprobar que el control lo reduce

Grupo 1 · rol Azul · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	04 de 10
Fase	2 — Ofensiva controlada
Grupo	1
Rol	Azul
Entrega	GitHub, carpeta semana_04/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Parte de su propia captura cruda y aplica el control equivalente: configuración, parche o regla de red. Repite el ataque para demostrar que falla y documenta el antes y el después.

- Leer su propia evidencia cruda y elegir el control que corta el ataque en el punto más barato.
- Aplicar el control y repetir el ataque para demostrar que ya no funciona.
- Documentar el antes y el después con los mismos comandos y la diferencia medida.

2 Qué aporta este rol al entregable

La mitigación aplicada, el comando de verificación y la comparación de resultados.

3 Ejemplo paso a paso

El rol Azul no se queda en el inventario: fija una linea base, aplica un control sobre un puerto concreto y repite la misma medicion. Lo que no se repite igual no demuestra nada.

3.1 Fijar la linea base con la tasa autorizada

La primera medicion se hace antes de tocar nada y con el limite de tasa del alcance. Se guarda la salida cruda y su hash.

```
mkdir -p semana_04/evidencia
nmap -sT -p 8081,3000,2222 --max-rate 20 127.0.0.1 \
  -oN semana_04/evidencia/antes.txt
sha256sum semana_04/evidencia/antes.txt > semana_04/evidencia/antes.
   sha256
```

3.2 Aplicar un control sobre un puerto

Se elige un control barato y reversible: denegar el puerto 2222 en el cortafuegos del host. Si el servicio debe seguir disponible para el grupo, se documenta la excepcion y no se aplica.

```
sudo nft add table inet filtro 2>/dev/null || true
sudo nft 'add chain inet filtro entrada { type filter hook input
   priority 0; }' 2>/dev/null || true
sudo nft add rule inet filtro entrada tcp dport 2222 drop
sudo nft list chain inet filtro entrada | tee semana_04/evidencia/regla
   .txt
```

3.3 Repetir la medicion y diferenciar

El mismo comando, sobre el mismo objetivo, con el control activo. El diff entre las dos salidas es la evidencia; si no cambia, el control no estaba donde se creia.

```
nmap -sT -p 8081,3000,2222 --max-rate 20 127.0.0.1 \
  -oN semana_04/evidencia/despues.txt
diff -u semana_04/evidencia/antes.txt semana_04/evidencia/despues.txt \
  | tee semana_04/evidencia/diff.txt
```

3.4 Revertir el control y dejar el laboratorio como estaba

Toda prueba tiene vuelta atras. Se elimina la regla, se verifica que el puerto responde otra vez y se anota el comando exacto que se uso.

```
sudo nft delete rule inet filtro entrada tcp dport 2222 drop 2>/dev/null || true
nmap -sT -p 2222 127.0.0.1 -oN semana_04/evidencia/revertido.txt
```

3.5 Puerto, estado y efecto del control

Puerto, estado y efecto del control

Puerto	Servicio	Antes	Control	Despues
8081	DVWA	Abierto	Sin control: fuera del ensayo	Abierto
3000	Juice Shop	Abierto	Sin control: fuera del ensayo	Abierto
2222	SSH	Abierto	Regla nftables con drop	Filtrado

"Cerrado" y "filtrado" no son lo mismo: el estado se copia de la salida de nmap, no se deduce.

4 Qué guardar en el repositorio

El informe incluye la linea base, el control aplicado con su regla, la medicion posterior, el diff y la reversion verificada.

```
semana_04/
|-- informe.md
|-- escaner.py
|-- evidencia/
|   |-- antes.txt
|   |-- despues.txt
|   |-- revertido.txt
|   |-- regla.txt
|   `-- diff.txt
`-- README.md
```

- Antes y despues usan exactamente el mismo comando y la misma tasa.
- La regla del cortafuegos se muestra con sudo nft list.
- La reversion se verifico y el servicio volvio a responder.
- El estado reportado coincide con la salida de nmap.

5 Cómo se corrige

Criterio	Peso
Huella digital completa (DNS/WHOIS)	2,0
Escáner funcional con técnicas solicitadas	3,0
Comparación rigurosa contra nmap	2,5
Explicación técnica de falsos positivos y sigilo	1,5
Código con type hints, docstrings y manejo de errores	1,0
Total	**10,0**

- {'Modificar el cortafuegos del host puede afectar otras sesiones': 'se revierte al terminar.'}
- Si el grupo necesita el puerto 2222, se elige otro puerto o se documenta la excepcion.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.